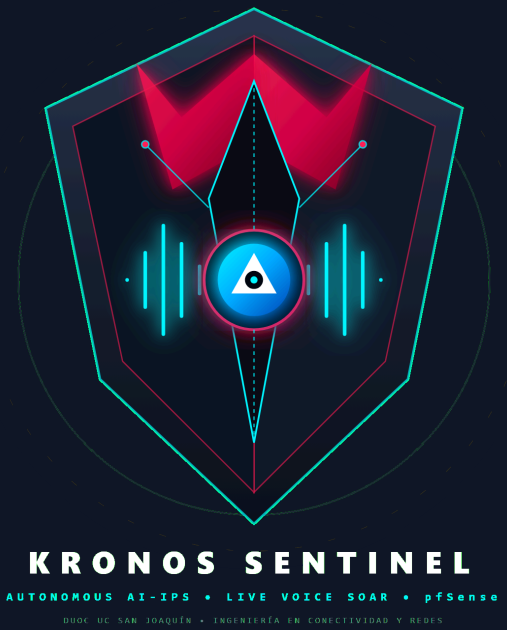
PTY4624 CAPSTONE · AVANCE DEL PROYECTO APT · FASE 2

KRONOS SENTINEL

Defensa perimetral que detecta, bloquea en el kernel y avisa por voz con IA al responsable de seguridad



Bruno Urrea
Líder · arquitectura de seguridad
A1 · A3 · A6 · A8 · borde AWS

Freddy Vásquez
Red y telefonía IP
A1 · A2 · A7 · A9

Cristóbal Quezada
Servicios web y DMZ
A5 HAProxy HTTPS + DVWA

Kevin Retamales
Hardening perimetral y QA
A4 pfBlockerNG · verificación A3 · QA (A10)

Equipo 5 · Docente: Claudia Reinoso · Ingeniería en Conectividad y Redes · Duoc UC San Joaquín · 27 de octubre de 2026

El proyecto en una mirada

Problema

Los SOC reciben más de un 50 % de alertas falsas y el aviso al CISO llega tarde.

Objetivo general

Diseñar, implementar y validar KRONOS SENTINEL: defensa SOAR de costo cero que bloquea al atacante en el kernel y avisa por voz con IA.

Objetivos específicos

10 objetivos medibles: 4 VLAN, IPS Inline, GeoIP y reputación, HTTPS con límites L7, correlación con más de 50 % menos falsos positivos, bloqueo con pfctl, llamada de voz y respuesta total menor a 1,5 s.

Alcance

Laboratorio virtual (Proxmox VE + AWS) con 6 VM y ataques web simulados (SQLi) contra DVWA.

No abarca

Red productiva de un cliente, hardware físico dedicado, operación SOC 24/7 ni ataques fuera de la capa web.

1. Ataque web (SQLi)
2. IPS Suricata + GeoIP y reputación
3. HAProxy: TLS y límites L7
4. Motor KRONOS: análisis AST
5. Bloqueo en kernel (pfctl · snort2c)
6. **Llamada de voz con IA al CISO**

Ajustes al proyecto y su origen

Ajuste	Origen	Justificación	Impacto en alcance o plazo
Borde público en AWS EC2 con túnel WireGuard	**Dificultad:** el enlace del laboratorio está tras CGNAT y no permite publicar servicios	Da una IP pública estable y conserva la IP original del atacante (sin SNAT), requisito de GeoIP, reputación y KRONOS	+1 VM (VM100 KRONOS-EDGE)
Guard IPS con cierre ante fallos	**Dificultad:** Suricata deja pasar tráfico unos 70 s mientras arranca	Cierra el tráfico en menos de 1,2 s si un motor cae y lo reabre solo cuando está listo: 0 escapes en 27 muestras	A3 cerró el 2-oct (+5 días)
FireHOL con supresión de redes privadas	**Dificultad:** la lista incluye rangos privados y CGNAT que cortarían la red interna	Bloquea solo direcciones públicas maliciosas sin afectar la gestión ni las VLAN	Tablas PF ampliadas a 2.000.000
HAProxy como paquete nativo de pfSense	**Facilitador:** pfSense integra HAProxy y un gestor de certificados	Termina TLS y aplica límites L7 en el mismo firewall, sin una VM adicional	A5 dentro de plazo (17–18 oct)
Adelanto de A6, A7 y A8; voz por puente EAGI de Asterisk	**Facilitador:** Asterisk en Docker y API Gemini disponibles antes de lo previsto	Permite probar el flujo completo antes de la QA final	Implementados en S11 (plan: S11–S15)
Evidencia a nivel de sistema operativo	**Retroalimentación docente:** las capturas de pantalla por sí solas no bastan	Salidas nativas de pfctl, haproxy -c y curl, con fecha y hora, además de las capturas	Colecciones A5 (18-oct) y A4 (25-oct)

Metodología: Top-Down Network Design + Kanban

Diseño de red: Top-Down Network Design (Oppenheimer, 2011)

FASE ACTUAL

1. Requisitos y objetivos
Guía 1: problema, objetivos medibles y restricción de costo cero

2. Diseño lógico
Plan VLAN e IP, políticas Zero Trust y flujo SOAR

3. Diseño físico
6 VM en Proxmox, borde AWS y troncal 802.1Q

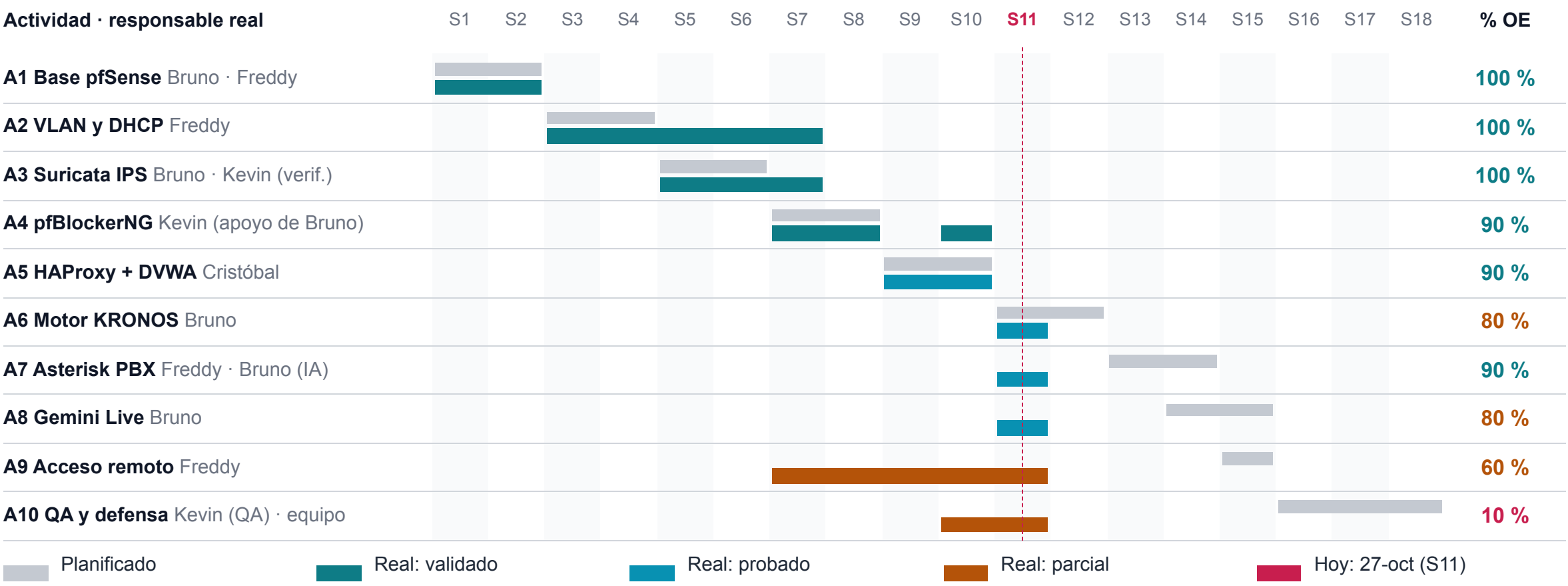
4. Pruebas, optimización y documentación
Criterios PASS/FAIL, evidencias fechadas y ajustes

Gestión: Kanban por estados de cada actividad (Anderson, 2010)

Por hacer (1)	Configurado (1)	Probado (4)	Validado (QA) (4)
A10 QA integral	A9 Acceso remoto (60 %)	A5 HAProxy	A1 Base pfSense
		A6 Motor KRONOS	A2 VLAN y DHCP
		A7 Asterisk	A3 Suricata IPS
		A8 Gemini Live	A4 pfBlockerNG

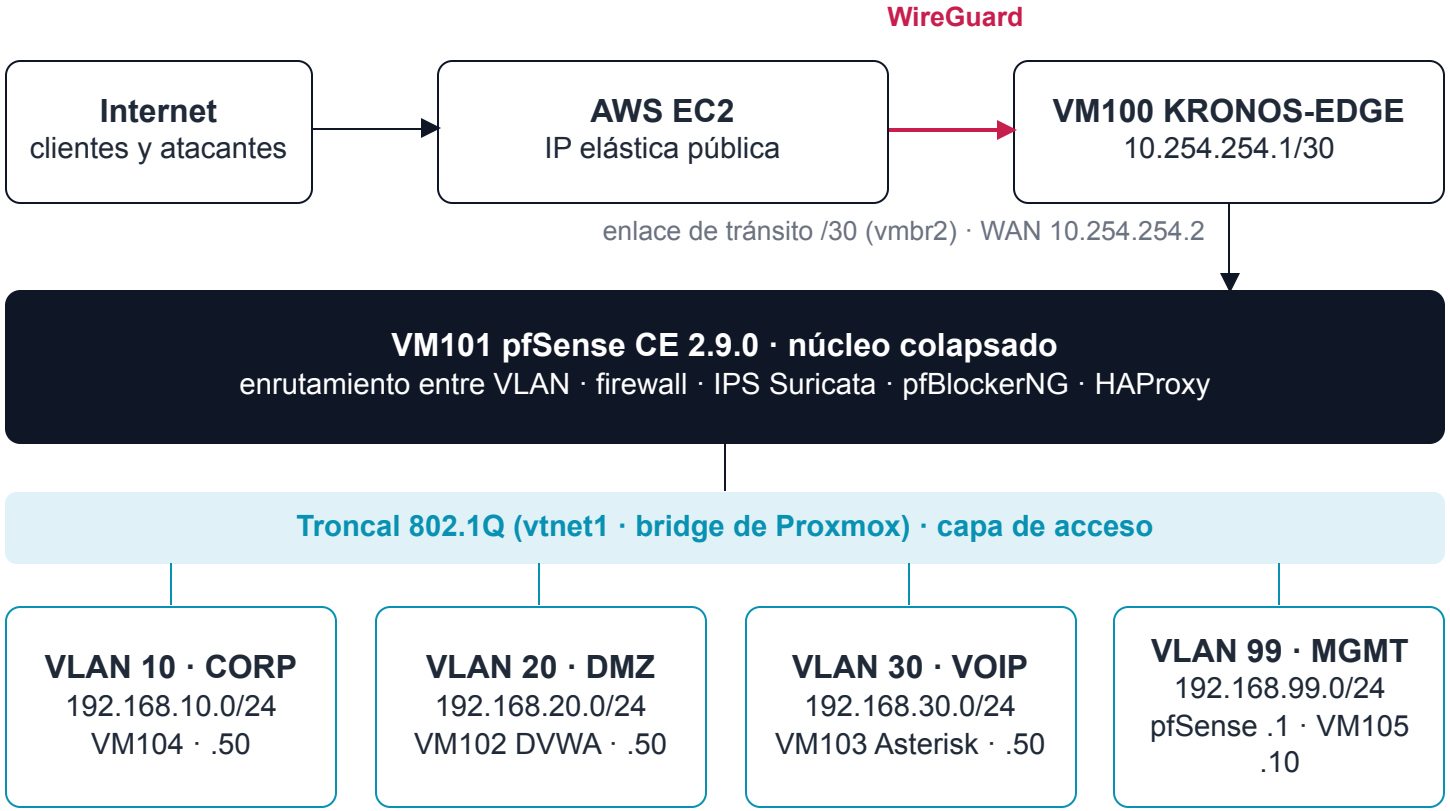
Artefactos: Carta Gantt plan vs. real · historial de GitHub y Pull Request #1 · colecciones evidencias/ con SHA-256 · informes de avance S7 · matriz de pruebas QA

Avance vs. planificación (semana 11)



Desviaciones y causa: A2 y A3 obtuvieron su evidencia el 2-oct (S7) tras rediseñar el borde por CGNAT y corregir el sensor interno del IPS. A4 aplica GeoIP a 2 de 6 países (RU y KP): justificación pendiente. A6, A7 y A8 se implementaron en S11, antes de lo planificado; su validación integral queda para A10.

Diseño técnico: topología y direccionamiento



WAN	↑	10Gbase-T <full-duplex>	10.254.254.2
MGMT	↑	10Gbase-T <full-duplex>	192.168.99.1
CORP	↑	10Gbase-T <full-duplex>	192.168.10.1
DMZ	↑	10Gbase-T <full-duplex>	192.168.20.1
VOIP	↑	10Gbase-T <full-duplex>	192.168.30.1

Captura real: interfaces de pfSense con su IP en cada VLAN.

Gateway .1 = pfSense en cada VLAN · DHCP .100–.199 · cada VLAN (capa 2) corresponde a una subred /24 (capa 3)

Modelo jerárquico

Borde: AWS + KRONOS-EDGE publican y tunelizan

Núcleo y distribución (colapsados): pfSense enruta entre VLAN y aplica políticas

Acceso: bridge 802.1Q de Proxmox, cada VM en su VLAN

Protocolos y justificación

802.1Q: segmenta por función sin hardware extra

WireGuard: túnel cifrado que atraviesa el CGNAT

DHCP por VLAN: direccionamiento automático por segmento

TLS + HTTP/2: cifrado web terminado en HAProxy

SIP (PJSIP) + RTP: señalización y audio de la llamada

Tailscale: administración sin abrir puertos

Simulación: ambiente y plan de pruebas

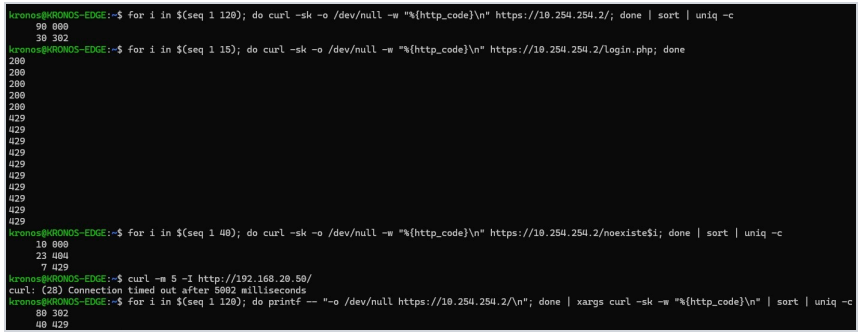
Ambiente: Proxmox VE · 6 VM | AWS EC2 + WireGuard | pfSense CE 2.9.0 | Suricata 7 | pfBlockerNG 3.2.17 | HAProxy 3.2.19 | Asterisk 20.6 | Python 3.12

Prueba	Esperado	Obtenido	Estado
A2 Aislamiento VLAN	Accesos y bloqueos según política	16 de 16 PASS	PASS
A3 IPS Inline	Firmas sin errores	26.628 y 26.629; 0 fallidas	PASS
A3 Guard IPS	Cierre en menos de 1,5 s	0,926 s y 1,177 s; 0 escapes	PASS
A4 Reputación y GeoIP	Bloqueo sin conexiones	2.930 paquetes; 0 estados	PASS
A5 HTTPS y límites L7	301 a HTTPS; 429 al abusar	429 tras 5 logins; DMZ sin acceso directo	PASS
A6 SQLi → kernel	IP en tabla snort2c	1=1 detectada; IP bloqueada	Simulado
A7–A8 Llamada al CISO	Llamada y respuesta por voz	Originate a ext. 1001; voz Gemini	Simulado
A10 Tiempo total	Menos de 1,5 s	Aún no medido	Pendiente

Más capturas originales en los anexos A a D (slides 11 a 14). «Simulado»: ataque generado en el laboratorio.

```
$ pfctl -vvs rules | grep -A1 "KRONOS A4"
@74 block drop in log quick on vtnet0
  <pfB_Europe_v4:13190> "KRONOS A4 GeoIP RU"
  [ Packets: 54   States: 0 ]
@76 ... <pfB_KRONOS_DROP_v4:1687> Spamhaus
  [ Packets: 1296 States: 0 ]
@77 ... <pfB_KRONOS_FIREHOL_v4:4623> FireHOL
  [ Packets: 1574 States: 0 ]
```

A4 · consola pfSense (25-oct): paquetes bloqueados por cada regla, sin conexiones abiertas.



A5 · consola EDGE (18-oct): 5 logins con 200 y luego 429; la DMZ directa da timeout.

Seguridad, QoS y tendencias

Seguridad

Implementado

- Denegación por defecto y aislamiento entre VLAN
- IPS Suricata Inline en la WAN y el troncal, con cierre ante fallos
- Reputación (Spamhaus DROP, FireHOL) y GeoIP en la WAN
- HTTPS con CA interna, cabeceras seguras y límites contra fuerza bruta
- Bloqueo automático del atacante con pfctl (tabla snort2c)
- Administración solo por la VLAN 99 y una tailnet separada

Tendencias

Implementado

- Nube: borde público en AWS EC2 con WireGuard
- Automatización: listas y GeoIP actualizadas cada día a las 00:00, infraestructura como código y suite de pruebas
- IA: agente de voz Gemini con herramientas SOAR

QoS

Pendiente

- VLAN 30 dedicada a voz y Asterisk operativo
- Priorización del tráfico de voz: se configura en A9 (23–29 nov)

2.930

paquetes maliciosos reales bloqueados en la WAN (A4)

< 1,2 s

cierre del tráfico si el IPS falla (A3)

429

respuesta de HAProxy desde el 6.º intento seguido de login (A5)

26.628

firmas Suricata activas en la WAN, 0 fallidas (A3)

Matriz de indicadores de calidad

8 logrados · 3 en curso

Ind.	Indicador de calidad	Evidencia	Estado
1.1	Implementa una red LAN/WAN según estándares de seguridad	Slide 6; A2 con 16 PASS (evidencias/2026-10-02)	Logrado
1.2	Entrega evidencia de la simulación de la red	Slide 7; colecciones fechadas en evidencias/	Logrado
2.1	Red de datos convergente con calidad de servicio	VLAN 30 de voz y Asterisk (A7); QoS sin configurar	En curso
2.2	Escalabilidad según el modelo de capas	Slide 6: núcleo colapsado y VLAN por servicio; tablas PF de 2.000.000	Logrado
2.3	Tecnologías emergentes: nube y automatización	Borde AWS; listas diarias; infraestructura como código (infra/)	Logrado
3.1	Servicios de red convergentes y escalables	DMZ (HAProxy + DVWA), VoIP (Asterisk) y gestión (VLAN 99)	Logrado
3.2	Plan de mantenimiento preventivo	Actualizaciones automáticas (pfBlockerNG, MaxMind, firmas ET); falta plan formal	En curso
3.3	Tendencias en servicios de red: virtualización y nube	Proxmox VE (6 VM) y AWS EC2	Logrado
4.1	Solución con políticas de seguridad	Slide 8; evidencias A3, A4 (25-oct) y A5 (18-oct)	Logrado
4.2	Plan de monitoreo permanente de la seguridad	Registros de Suricata y pfBlockerNG + motor KRONOS; plan formal en A10	En curso
5.1	Solución con tendencias tecnológicas	Arquitectura SOAR con IA de voz (A6–A8)	Logrado

Próximos pasos y cierre

Pendientes hacia el informe final

Prueba de acceso a DVWA desde Internet por el borde AWS
Cristóbal · antes del 3-nov

Justificar o ampliar el alcance GeoIP (RU y KP de 6 países)
Kevin y Bruno · antes del 3-nov

Captura nativa del bloqueo en la tabla snort2c (A6)
Bruno · antes del 3-nov

QoS de voz, softphones y ACL de acceso remoto (A9)
Freddy · 23–29 nov

QA integral: tiempo total menor a 1,5 s, supresión de más de 50 % y SQLi a través de HAProxy; planes de mantenimiento y monitoreo
Kevin y equipo · 30-nov al 20-dic

Riesgos y mitigación

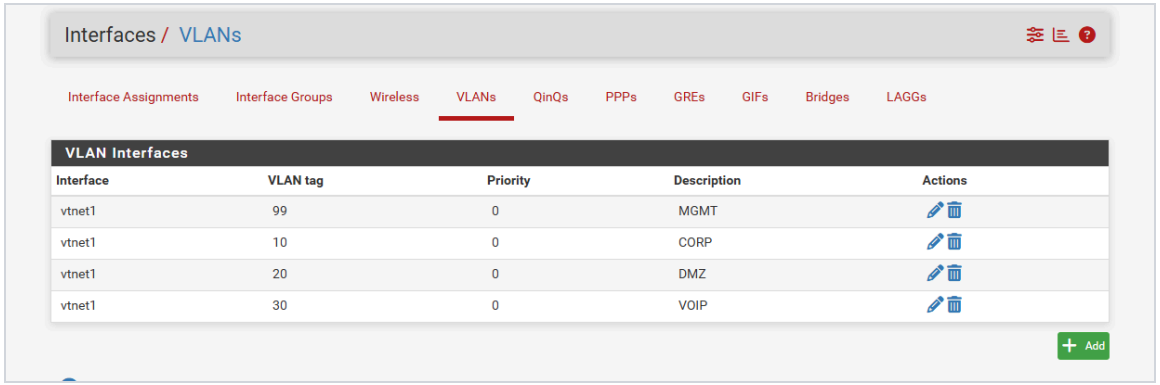
Falla del laboratorio remoto el día de la defensa
Capturas y salidas nativas de respaldo; guion de pruebas ensayado

Cuota o latencia de la API de Gemini
Medir en A10 y definir un modo degradado

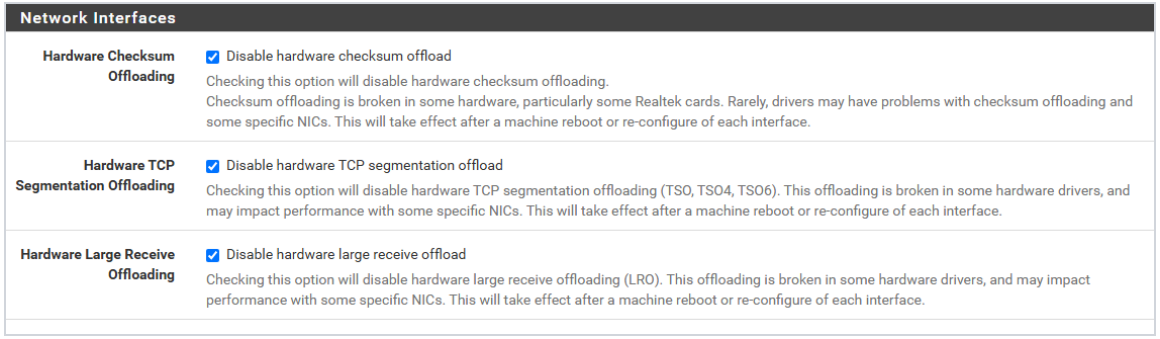
Listas de amenazas que cambian a diario
Actualización automática a las 00:00 y revisión de alertas

KRONOS SENTINEL ya detecta, bloquea y avisa en el laboratorio. La Fase 3 debe demostrar que lo hace en menos de 1,5 s y de forma confiable.

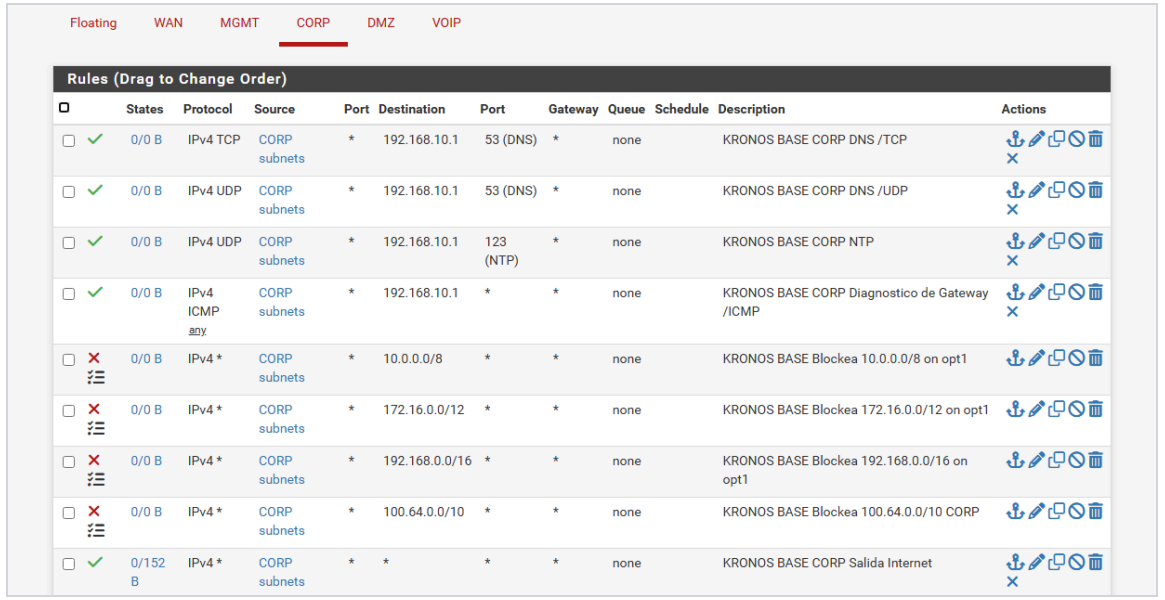
Anexo A · pfSense y segmentación (A1–A2)



Interfaces › VLANs: las 4 VLAN 802.1Q (10, 20, 30 y 99) sobre el troncal vtnet1.

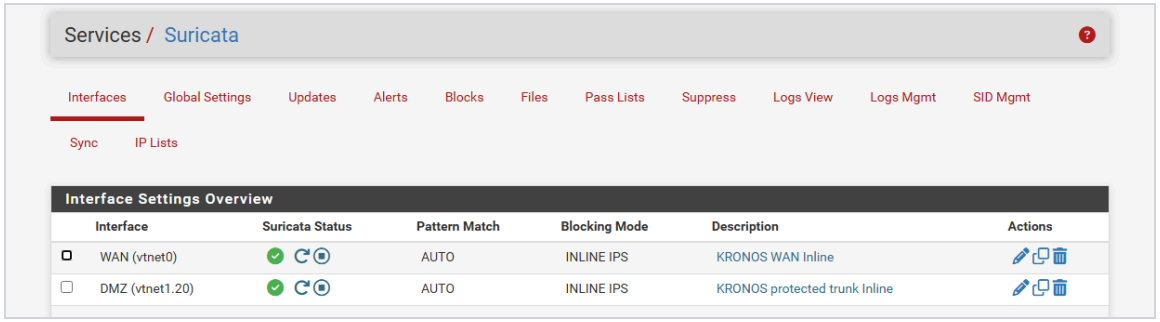


System › Advanced › Networking: offloading de hardware desactivado, requisito del IPS Inline (A1).

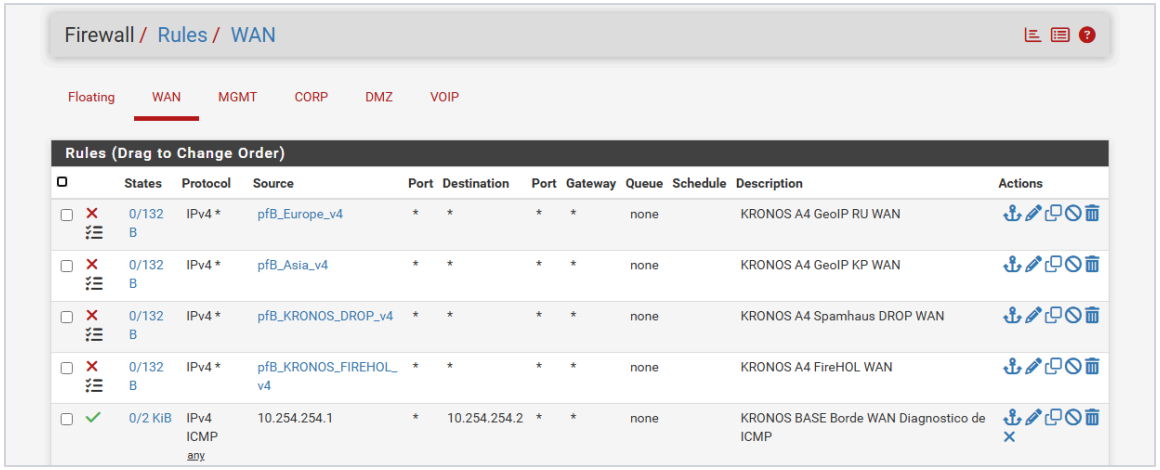


Firewall › Rules › CORP: permite DNS, NTP y diagnóstico al gateway; bloquea las demás redes privadas y deja salir a Internet.

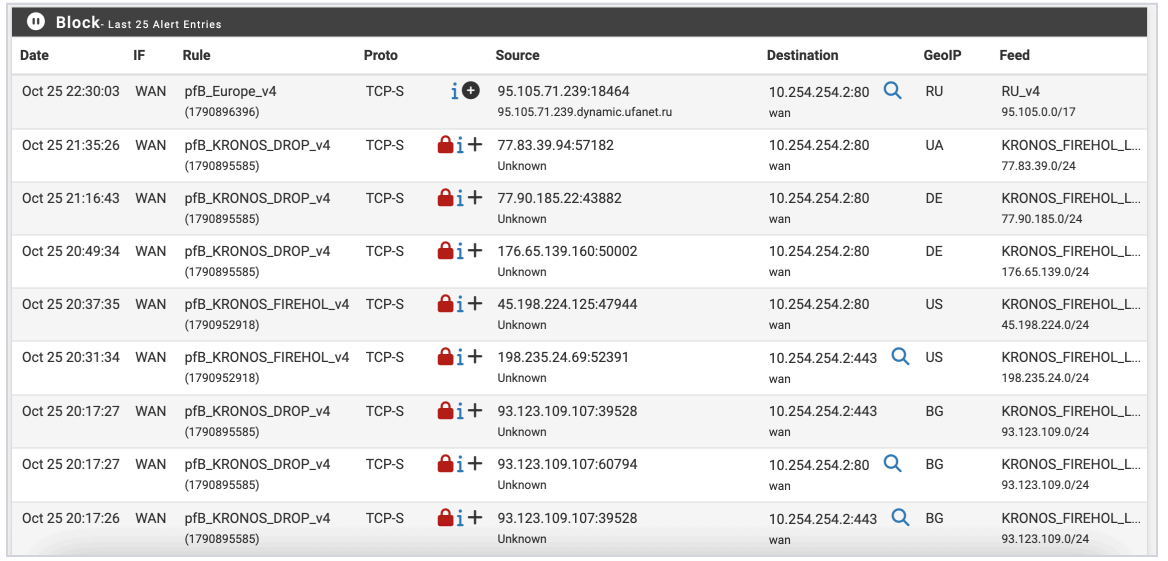
Anexo B · IPS y reputación (A3–A4)



Services › Suricata: IPS en modo INLINE en la WAN y en el troncal interno, ambos activos.



Firewall › Rules › WAN: las 4 reglas A4 bloquean GeoIP (RU y KP), Spamhaus DROP y FireHOL.

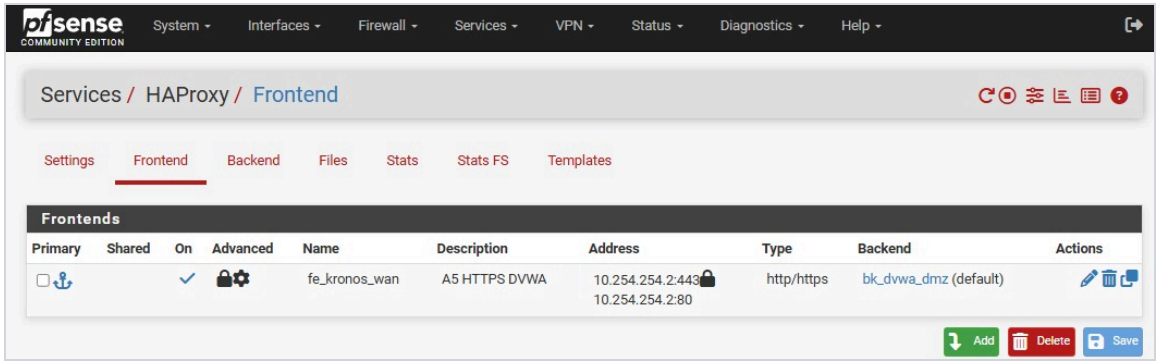


pfBlockerNG › Alerts (25-oct): ataques reales bloqueados, con país y lista de origen.

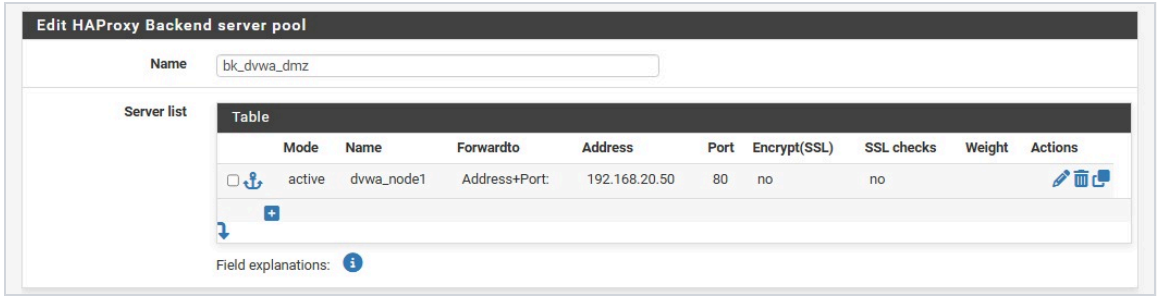
```
$ tail /var/log/pfblockerng/pfblockerng.log
 UPDATE PROCESS START [ v3.2.17_1 ] [ 10/25/26 00:00:03 ]
[ KRONOS_SPAMHAUS_DROP_v4 ] Downloading update .. 200 OK.
 Updating: pfB_KRONOS_FIREHOL_v4
 15 addresses added. 23 addresses deleted.
```

Registro de pfBlockerNG: las listas se actualizan solas cada día a las 00:00.

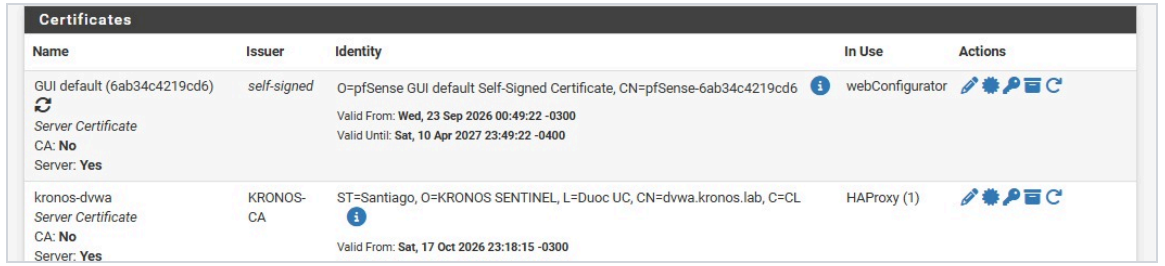
Anexo C · HAProxy HTTPS y DVWA (A5)



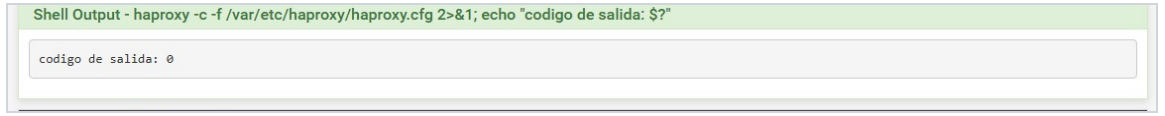
Services › HAProxy › Frontend: fe_kronos_wan escucha en 443 (TLS) y 80 y envía el tráfico a DVWA en la DMZ.



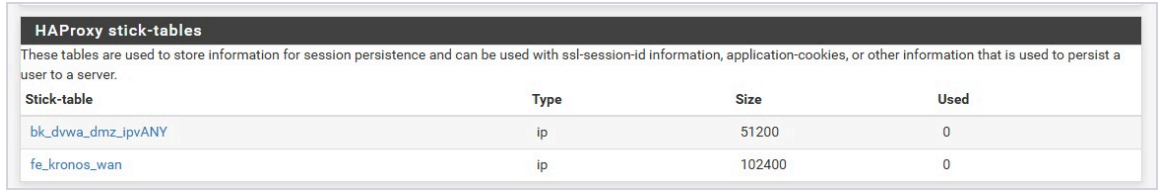
Services › HAProxy › Backend: el servidor dvwa_node1 apunta a 192.168.20.50:80, en la DMZ.



System › Certificates: certificado kronos-dvwa firmado por la CA interna KRONOS-CA, en uso por HAProxy.



Command Prompt: haproxy -c valida la configuración sin errores (código 0).



HAProxy › stick-tables: tablas que cuentan las peticiones por IP para aplicar los límites (429).

Anexo D · Motor KRONOS y llamada de emergencia (A6–A8)



Asterisk 20.6 (VM103): la extensión 1001 del CISO está registrada desde la VLAN de gestión.

```
$ cat docs/obsidian_vault/incident_memory.json  (extracto)
"185.220.101.5": { "count": 13,
  "first_seen": "2026-10-26T00:54:12Z",
  "target_services": ["DVWA en DMZ (192.168.20.50)"],
  "actions": ["DROP & BLOCK en Firewall pfSense"] }
```

Memoria de incidentes: la IP atacante simulada reincidió 13 veces y quedó bloqueada con pfctl.

```
$ cat docs/QA_AUDIT_REPORT_A1_A7.json  (extracto)
"GATE_2_AST_ANALYSIS": { "status": "PASSED",
   "tautologies": ["1=1"], "confidence": 0.85 }
"GATE_3_PFCTL_KERNEL": { "status": "PASSED",
   "table": "snort2c", "is_blocked": true }
"GATE_7_GEMINI_LIVE": { "status": "PASSED",
   "voice": "Aoede" }
"GATE_8_ASTERISK_A7": { "status": "PASSED",
   "ami_host": "192.168.30.50:5038" }
```

Suite de pruebas (26-oct): SQLi detectado, IP bloqueada en snort2c y llamada por AMI. Ataque simulado.